Operating System Security

Week 4: More on Windows Security

Beware: Magic Names

Many programs allow configuration files to be created, and when the configuration file is clicked, it modifies the related system settings

- E.g., registry settings can be imported using .reg files.

Windows has dozens of files that will be read and executed a certain way just because of their name.

- E.g., the file called “Autorun.inf” on a CD-ROM or DVD disk will be presented as the first option for the action for the user to take when the removable media is first inserted.
- Earlier versions used to execute automatically

Beware: Malicious File Tricks

File Naming Tricks, e.g., call a file Readme.txt.exe but Windows (some versions) will display just Readme.txt

- Also long file names and unprintable characters

Take a look (on Windows 10):

- Windows Explorer-> View -> Options -> Change Folder and Search Options -> View

You should:

- Make sure “Hide Extensions for Known File Types” is not selected
- Disable “Hide protected operating system files (Recommended)”
- Select “Show hidden files and folders”

File Defenses

Uninstall, Remove, Delete and Rename

- The best way to minimize the threat of malicious exploit from high-risk files and programs is not to have them installed in the first place.

Use NTFS Permissions

- For every high-risk file and unused application, prevent non-Admin users from being able to execute the file.
- Create a Least Privilege Users Group

Windows Vulnerabilities - Registry

The registry is a global, hierarchical database to store data for all programs.

- Contains security-sensitive information such as paths to libraries and exes to be loaded for the app.

These registry entries should be protected, and can be associated with a security context that limits access

- However, not always effectively used. E.g., AOL added a registry entry that specified the name of a DLL to be loaded, but permissions were set such that any user could write to the entry.
- This is often done because software vendors want to ensure everything runs smoothly, without access issues on install/running.

Registration Database (Registry)

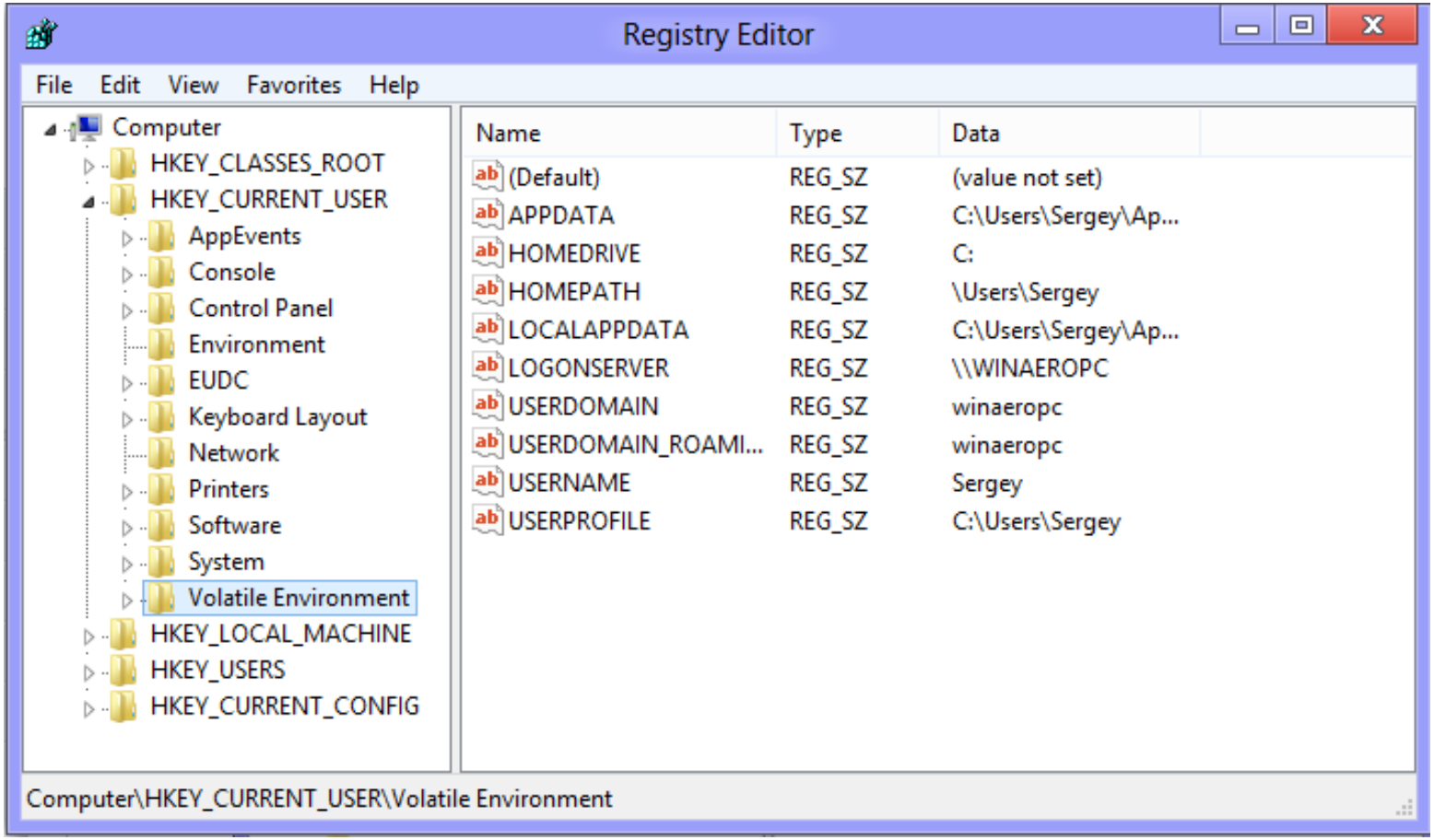
Microsoft introduced the registration database (the registry) to locate configuration information in one location.

Most applications and even Windows installed their own configuration files (e.g., .ini file extension).

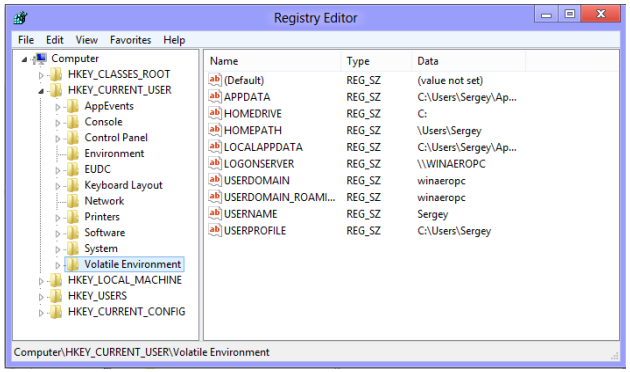
Microsoft had reportedly intended to replace the registry with the Windows File System (WinFS) in Vista. This did not happen – it was planned but then scrapped.

Manipulating the Registry

Programs can do it (using Windows API), but administrators can manipulate it through regedit:



Registry Root Keys



HKEY_CLASSES_ROOT (HKCR)

- hardware/OS data of this computer

HKEY_CURRENT_USER (HKCU)

- Object Linking and Embedding (OLE) and file-class association data

HKEY_LOCAL_MACHINE (HKLM)

- profile for user logged on interactively

HKEY_USERS (HKU)

- actively used profiles of non-remote users

HKEY_CURRENT_CONFIG (HKCC)

- hardware profile

Registry Structure

Under each root are keys, subkeys, values and data – making up thousands of separate database entries.

Keys are the first level under a root, followed by the lower subkeys, the subkey values, and the data of each value.

There can be one or more values under each subkey.

Each value can contain data, whether decimal, binary, and ASCII string.

Registry and the Windows API

Windows API is a Microsoft operating systems core set of Application Programming Interface (API) functions.

- Any developer can make use of these when developing an application for Windows.

Windows allows applications to manipulate the registry (if access is allowed).

- Remember: registry keys are objects that permissions can be applied to (i.e., they have ACLs).

Registry Functions in the Windows API

List of registry functions:

- http://msdn.microsoft.com/en-us/library/windows/desktop/ms724875(v=vs.85).aspx

See the following example for how to enumerate registry subkeys and values of a particular key:

- http://msdn.microsoft.com/en-us/library/windows/desktop/ms724256(v=vs.85).aspx

Registry Best Practice

One incorrect edit to the registry can crash the operating system

- If you are not completely sure about what you are doing, then don't do it

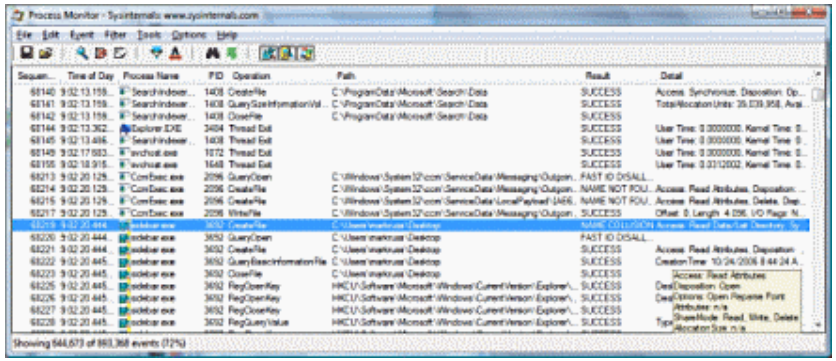
Backup before you modify it

- Export/import registry hives

Limit accesses to registry

Log and monitor registry activity

Process Monitor



You can download it here: :
http://technet.microsoft.com/en-us/sysinternals/bb896645

Example of typical use of ProcessMonitor

- http://www.youtube.com/watch?v=SH_JqB_XwWg

The above example demonstrates the use of filters to focus on certain processes.

- You can also set filters on particular operations (e.g., opening of registry keys), time, duration, company name, parent process name, … and many more.

Limit Accesses to the Registry

What you can do in regedit

- Assign (customized) permissions to a registry key to users or groups
- Audit users/groups' activity on a registry key

Auditing Registry Keys

You can specify (through regedit) that a particular key be audited

- Certain permissions being granted to a particular user or group
- Can have auditing entries for one or more users and groups

Must right-click on a key and then go to permissions - advanced tab, then the auditing tab.